

Implementing Operational Cyber Resilience in the IT Sector Using the Operational Resilience Framework

1. Introduction and Problem Statement

Cyber resilience is defined by the Federal Reserve as an organization's ability to prepare for, respond to, and recover from a cyber incident while sustaining operations and fulfilling the organization's mission.^[1] By this definition, cybersecurity is a matter of enterprise risk management. The information technology (IT) sector faces this issue. Technology companies, managed service providers, and software vendors are at the center of nearly every sector. A breach in an IT organization can affect customers, the supply chain and vital downstream services. For example, in the 2019 SolarWinds supply chain attack, the threat actors introduced a backdoor to the SolarWinds Orion software, a software used by 18,000 organizations. The threat actors had access to US government agencies and private sector networks for several months before being detected.^[2] Most recently, in July 2024 a buggy update to cybersecurity vendor CrowdStrike crashed 8.5 million Windows systems worldwide, including those of airlines, hospitals, banks and governments. This caused a USD 5.4 billion loss to Fortune 500 companies caused not by a cyberattack, but by a single point of failure in a trusted vendor's update mechanism.^[3] The two incidents together illustrate the risk created when IT organizations lack the resilience architecture required for IT failure. A single node failure, can propagate to the other systems which depend on it. This paper outlines the application of the Operational Resilience Framework (ORF) to a mid-sized IT organization, leveraging the NIST SP 800-207 technical architecture^[4] and the CISA Zero Trust Maturity Model^[5] as reference objectives for the successful implementation of the ORF.

2. Framework and Model

While this paper details the technical implementation of the ORF, it must exist within the parameters of the NIST SP 800-207 Zero Trust architecture.^[4] The reason to use NIST SP 800-207 is simple, it is a leading federal standard for Zero Trust and has concrete architectural tenets. The Policy Engine that makes access decisions, the Policy Administrator that enforces them, and the Policy Enforcement Point, which gives the final push to grant access to resources, together give IT organizations a framework to build identity-based, continuously validated access controls in complex IT environments. Such architectural precision is essential in an industry where privileged access to production systems and client infrastructure are the everyday norm.

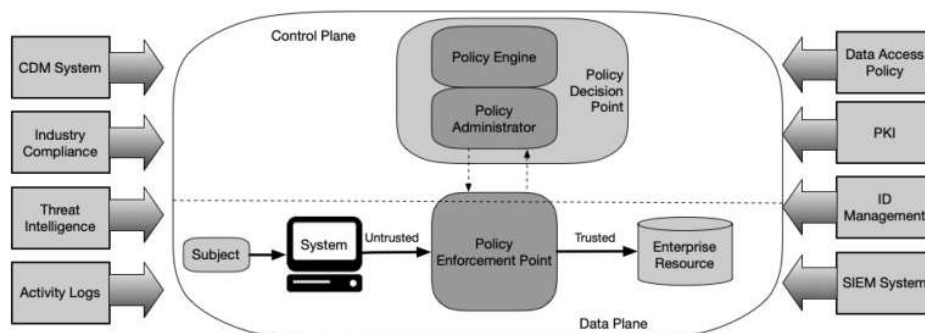


Figure 2: Core Zero Trust Logical Components

Figure 1: Core Zero Trust Logical Components — NIST SP 800-207 (NIST, 2020) [4]

As shown in Figure 1, the architecture is divided into two sections. The Control Plane contains Policy Decision Point (PDP), which consists of a Policy Engine and Policy Administrator. It analyzes the access request against enterprise policy rules, threat intelligence, activity history, and current compliance signals. The Data Plane consists of the Policy Enforcement Point (PEP), which enforces the PDP decision by establishing a secure connection between the subject requesting access and the enterprise resource being accessed.^[4]

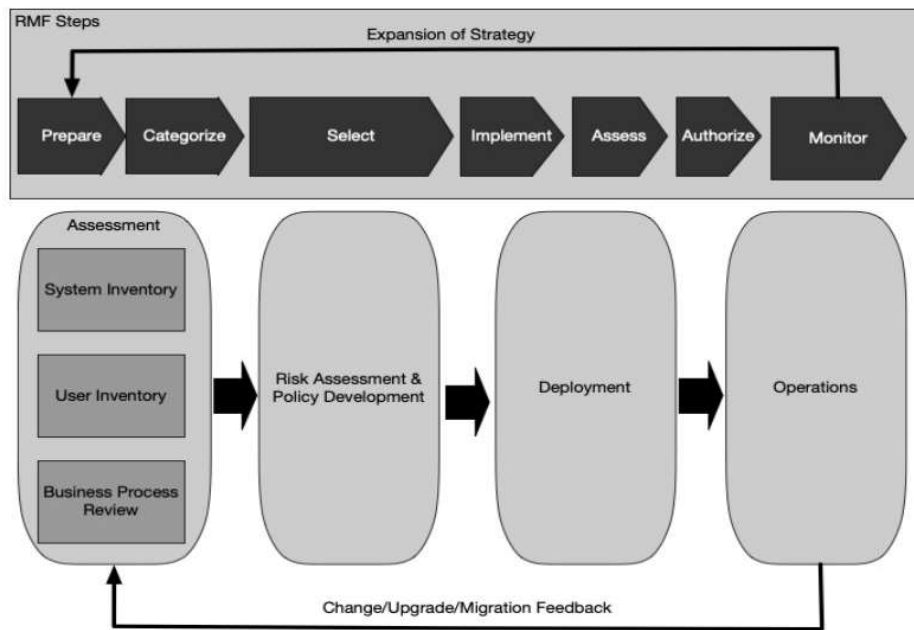


Figure 12: ZTA Deployment Cycle

Figure 2: ZTA Deployment Cycle — NIST SP 800-207 (NIST, 2020) [4]

Figure 2 illustrates how Zero Trust Architecture works practically. The upper flow chart depicts the implementation to the NIST RMF, providing a governance structure which can be incorporated into existing IT organizational risk management processes.^[4] In the bottom portion, deployment is split into four steps, Assessment (an inventory of systems, users and a review of business processes), Risk Assessment and Policy Development (which results in defined access policies), Deployment (which implements the architecture) and Operations (the active monitoring phase). These in turn are fed by a feedback loop called Change, Upgrade and Migration which feeds back into Assessment, reflecting the ORF's view that resilience is not a project, but an evolving capability.

The CISA Zero Trust Maturity Model (ZTMM) is CISA's zero trust maturity benchmarking tool.^[5] The model maps to the architecture defined in NIST SP 800-207, and has metrics that fall into the five pillars of Identity, Devices, Networks, Applications and Workloads, and Data, with maturity levels of Customary, Initial, Advanced, and Optimal. This prevents Zero Trust from being regarded as an all-or-nothing transformation and gives IT organizations a structured roadmap with clear milestones.

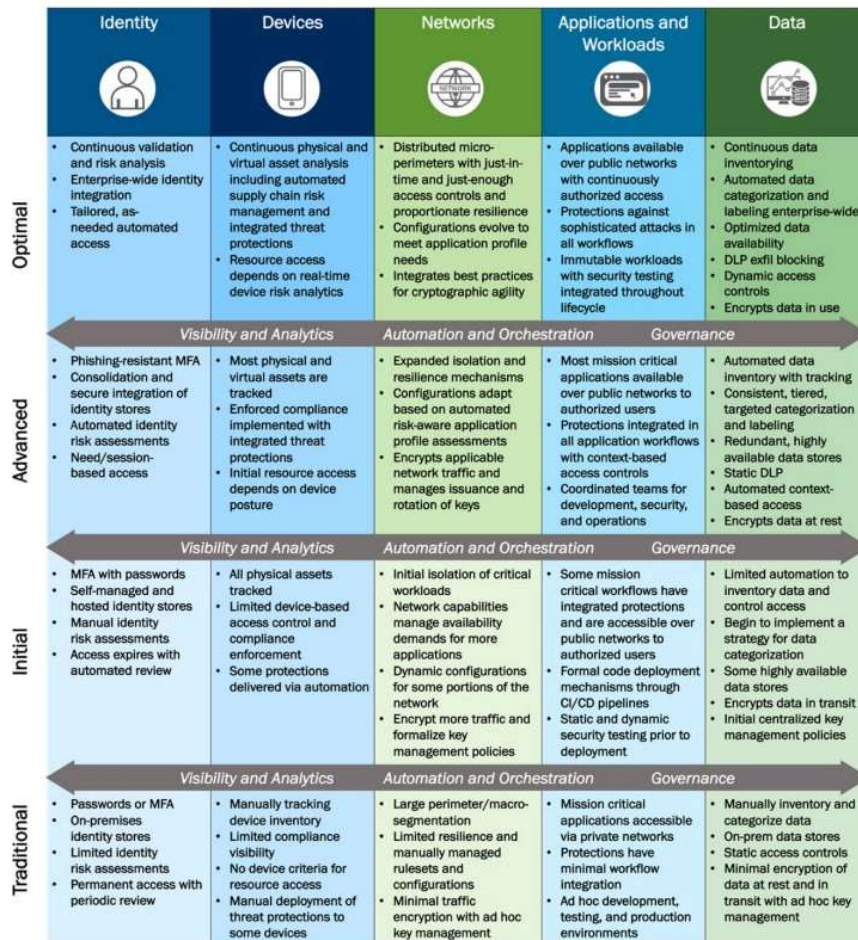


Figure 4: High-Level Zero Trust Maturity Model Overview

Figure 3: CISA Zero Trust Maturity Model — High-Level Overview (CISA, 2023) [5]

As illustrated in Figure 3, no organization starts with optimal maturity. For example, in the Identity pillar, traditional maturity includes access with passwords or basic MFA and limited risk assessment; stage 2 – Initial adds automated access expiration; and Stage 3 – Advanced adds phishing-resistant MFA and session-based access. At Optimal maturity, the organization will now have continuous validation and risk analysis and tailored as-needed automated access. All five pillars reflect this thought process. The ZTMM guides in calculating the operating level for the ORF strategy to maintain resilience goals into an actionable and measurable outcome across the complete environment.^[5]

3. Strategy and Organizational Approach

A resilience strategy in the ORF must address four sets: people, process, technology, and organizational governance. A weakness in any one of these sets can weaken others, which is why the ORF is important, especially since it treats resilience as a systemic property rather than a technical checklist.^[6]

People

In IT, however, humans are the weakest link in the security chain. Attacks like Phishing and social engineering continue to work. Developers should be trained on secure coding practices, and the dangers of dependency poisoning. Systems administrators should be trained in privilege escalation and least privilege enforcement.^[7] Identity management must adhere to the principle of least privilege, reviewing and re-issuing or terminating access when staff change jobs. Identity management should also support the Zero Trust principle of verifying a user's identity for every access request rather than implicitly granting trust.^[4]

Process

From a resilience perspective, ORF recommends conducting a Business Impact Assessment (BIA) to identify critical services.^[6] Examples include source code repositories, CI/CD pipelines, customer websites and applications, and managed services provided by the IT organization to their clients. There is a risk register with threats, controls, residual risks and owners, including supply chain dependency on third-party libraries and vendor platforms. Regularly running tabletop and incident response exercises ensures that in a ransomware attack, or a compromise to the software development supply chain, the impacted organization is not making life or death decisions for the first time.^[8]

Technology

As seen earlier in NIST SP 800-207, many components of Zero Trust architecture drive operational resilience.^[4] In real-time, operational resilience can be accomplished through MFA, network segmentation (reduce lateral movements), EDR solutions, and data encryption both in transit and at rest. A SIEM platform supports real-time detection and forensics after an incident throughout the protect, detect, and defend lifecycle.

Organizational Governance

To be effective, cybersecurity must be sponsored at the executive level, which should be an enterprise-wide process. It should be oversighted by a committee with members from the engineering team, legal team, compliance team, and customers team that reports to the leadership team on MTTD and MTTR, system uptime, training completion, and third-party vendor assessment coverage. Another area of governance is vendor risk management, as any platform or third-party tool can help for exposure, and should be subject to assessments and contractual obligations to report any incidents.

4. Tools for Implementation

Currently, there are many tools available that can execute this strategy.

- a. Risk register structured around the shared responsibility model illustrates the company's own risks as well as those shared with vendors or cloud providers.
- b. IAM platforms like Okta maintain identity governance and MFA Compliance.
- c. SIEMs like Splunk or Microsoft Sentinel collect log data and automate real-time detection.
- d. Vulnerability management platforms like Tenable help with tracking unpatched systems.
- e. The GRC platform unites these tools together by tracking policy compliance, risk register updates, and audit fidelity in one place.

5. Areas for Future Development

The ORF could include guidance on measuring resilience outcomes, in addition to implementing the controls. Many organizations find it difficult to cascade Zero Trust maturity scores into business-level metrics meaningful to audiences without a technical background. Supply chain resilience needs work, especially with new SBOM requirements and security standards for open-source dependencies. In addition, given that AI-enabled attacks such as automated vulnerability discoveries and targeted AI-generated phishing emails based on roles are not covered by ORF and NIST SP 800-207, it will be necessary for them to update their documents in this regard.^[4]

6. Conclusion

When adopted in information technology, the ORF supports the collaboration of people, process, technology, and governance to establish a principled, practical, and measurable resilience program across the full protect, detect, and defend lifecycle with NIST SP 800-207^[4] and the CISA Zero Trust Maturity Model,^[5] and others. IT infrastructure undergirds every other sector and, accordingly, its resilience has national implications. A disciplined, continually improving approach to resilience is a necessity.

7. References

- [1] Board of Governors of the Federal Reserve System. Cybersecurity and Financial System Resilience Report. 2022. <https://www.federalreserve.gov/publications/files/cybersecurity-report-202207.pdf>
- [2] The National Counterintelligence and Security Center. SolarWinds Orion Software Supply Chain Attack. August 19, 2021. <https://www.dni.gov/files/NCSC/documents/SafeguardingOurFuture/SolarWinds%20Orion%20Software%20Supply%20Chain%20Attack.pdf>
- [3] The Guardian. CrowdStrike global outage to cost US Fortune 500 companies \$5.4bn, July 24, 2024. <https://www.theguardian.com/technology/article/2024/jul/24/crowdstrike-outage-companies-cost>
- [4] National Institute of Standards and Technology. Zero Trust Architecture. SP 800-207. U.S. Department of Commerce. August 2020. <https://doi.org/10.6028/NIST.SP.800-207>
- [5] Cybersecurity and Infrastructure Security Agency. Zero Trust Maturity Model, Version 2.0. April 2023. https://www.cisa.gov/sites/default/files/2023-04/zero_trust_maturity_model_v2_508.pdf
- [6] Hillel-Tuch, Alon. CS-CG 9215 — *Week 1: Intro to Resilience*. Center for Cyber Security. Tandon School of Engineering. New York University.
- [7] Hillel-Tuch, Alon. CS-CG 9215 — *Week 4: Zero Trust*. Center for Cyber Security. Tandon School of Engineering. New York University.
- [8] Cybersecurity and Infrastructure Security Agency. CISA Tabletop Exercise Packages. 2024. <https://www.cisa.gov/resources-tools/services/cisa-tabletop-exercise-packages>